



**DRAFT PRODUCT DESCRIPTION (PD)
DEPARTMENT OF VETERANS AFFAIRS**

**Office of Information & Technology (OIT)
Office of Information Security (OIS)**

Zero Trust Data Monitoring and Sensing - Structured Data Protection

**VA-26-00050089
PD Version Number: 1.1
Date: April 14, 2025**

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

1.0 PRODUCT REQUIREMENTS

The Department of Veterans Affairs (VA), Office of Information & Technology (OIT), Office of Information Security (OIS) requires a comprehensive Zero Trust Data Monitoring and Sensing - Structured Data Protection solution that provides a data protection solution to address on-premises structured data, and structured data in the VA Enterprise Cloud (VAEC) Cloud environments to include- Amazon Web Services (AWS) and Azure. Data Monitoring and Sensing is essential for enhancing cybersecurity measures across VA's enterprise environments, supporting VA's Zero Trust Architecture Strategy in line with Executive Order 14028, Improving the Nation's Cybersecurity. The Zero Trust Data Monitoring and Sensing - Structured Data Protection solution shall provide robust Data Loss Prevention (DLP) capabilities, including automated enforcement of policies to prevent unauthorized access, transfer, or exfiltration of sensitive structured data. In addition, the solution must support automated and persistent data labeling, ensuring labels are applied consistently to structured data assets and integrated with DLP policies for dynamic access control and compliance.

DLP and labeling integration should align with VA's Zero Trust principles and classification standards, enabling continuous verification, least privilege access, and adaptive policy enforcement across on-premises and cloud environments

This solution shall be a commercial off-the-shelf (COTS) product or an equivalent turnkey implementation that delivers end-to-end security capabilities, including management, threat detection, runtime policy enforcement, support, and virtual patching.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. "Federal Information Security Modernization Act of 2014"
2. Federal Information Processing Standards (FIPS) Publication 140-3, "Security Requirements for Cryptographic Modules", March 22, 2019
3. FIPS Pub 199. "Standards for Security Categorization of Federal Information and Information Systems," February 2004
4. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
5. FIPS Pub 201-3, "Personal Identity Verification of Federal Employees and Contractors," January 2022
6. 10 U.S.C. § 2224, "Defense Information Assurance Program", as amended
7. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

8. Public Law 109-461 (P.L. 109-461), Veterans Benefits, Health Care, and Information Technology Act of 2006, as amended, Title IX, Information Security Matters
9. 42 U.S.C. § 2000d “Title VI of the Civil Rights Act of 1964”, as amended
10. VA Directive 0710, “Personnel Security and Suitability Program,” June 4, 2010, <https://www.va.gov/vapubs/index.cfm>
11. VA Handbook 0710, “Personnel Security and Suitability Program,” May 2, 2016, <https://www.va.gov/vapubs/index.cfm>
12. VA Directive 6102, “Internet/Intranet Services,” August 5, 2019
13. 36 C.F.R. Part 1194 “Information and Communication Technology Standards and Guidelines,” as amended
14. Office of Management and Budget (OMB) Circular A-130, “Managing Federal Information as a Strategic Resource,” July 28, 2016
15. 32 C.F.R. Part 199, “Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)”, as amended
16. National Institute of Standards and Technology (NIST) SP 800-66 Rev. 2, “Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,” February 2024
17. 45 C.F.R. Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information (“Privacy Rule”); and 45 C.F.R. Parts 160 and 164, Subparts A and C, the Security Standard (“Security Rule”); as amended
18. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended
19. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
20. VA Directive 6500, “VA Cybersecurity Program,” February 24, 2021 (see VA NOTICE 24-18, dated September 27, 2024, “Update to VA Directive 6500 Cybersecurity Program”, and VA Notice 25-07, dated 3/18/25, “Amending VA Directive 6500 to incorporate M-24-15”)
21. VA Handbook 6500, “Risk Management Framework for VA Information Systems VA Information Security Program,” February 24, 2021 (see VA Notice 25-01, dated October 15, 2024, “Update to VA Handbook 6500 Risk Management Framework for VA Information Systems VA Information Security Program”, and VA Notice 25-06, dated 3/18/25, “Amending VA Directive 6500 to incorporate M-24-15”)
22. VA Handbook 6500.2, “Management of Breaches Involving Sensitive Personal Information (SPI),” June 30, 2023
23. VA Handbook 6500.6, “Contract Security,” March 12, 2010 (see VA Notice 24-12, dated April 22, 2024, “Update to VA Handbook 6500.6, Contract Security, Appendix C VA Information and Information System Security/Privacy Language For Inclusion Into Contracts, As Appropriate”)
24. VA Handbook 6500.8, “Information System Contingency Planning,” March 25, 2025
25. VA Handbook 6500.10, “Mobile Device Security Policy,” February 15, 2018
26. VA Handbook 6500.11, “VA Firewall Configuration,” August 22, 2017

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

27. OIT Process Asset Library (PAL), [OIT Process Asset Library](#).
28. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
29. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
30. VA Directive 6510, "VA Identity, Credential and Access Management," September 3, 2024
31. VA Handbook 6510, "VA Identity, Credential and Access Management," September 27, 2024
32. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
33. VA Directive 6300, "Records and Information Management," September 21, 2018
34. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
35. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
36. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)
37. VA Directive 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," October 26, 2015
38. VA Handbook 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," March 24, 2014
39. OMB Memorandum 05-24, "Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors," August 5, 2005
40. OMB Memorandum M-19-17, "Enabling Mission Delivery Through Improved Identity, Credential, and Access Management," May 21, 2019
41. OMB Memorandum, "Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation," May 23, 2008
42. Federal Identity, Credential, and Access Management (FICAM) Architecture, June 30, 2023 ([FICAM Architecture \(idmanagement.gov\)](#))
43. NIST SP 800-116 Rev 1, "Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access," June 2018
44. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, "Digital Identity Guidelines," updated March 02, 2020
45. NIST SP 800-157, "Guidelines for Derived PIV Credentials," December 2014
46. VA Memorandum, VAIQ #7100147, "Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12)," April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

47. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
48. VA Memorandum “Personal Identity Verification (PIV) Logical Access Policy Clarification,” July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
49. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
50. OMB Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative,” September 12, 2019
51. OMB Memorandum M-08-23, “Securing the Federal Government’s Domain Name System Infrastructure,” August 22, 2008
52. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (P.L. 110–140), December 19, 2007
53. Section 104 of the Energy Policy Act of 2005, (P.L. 109–58), August 8, 2005
54. Executive Order 13221, “Energy-Efficient Standby Power Devices,” August 2, 2001
55. VA Directive 0057, “VA Environmental Management Program,” October 25, 2022
56. Office of Information Security (OIS) VAIQ #7424808 Memorandum, “Remote Access,” January 15, 2014, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
57. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
58. “Veteran Focused Integration Process (VIP) Guide 4.0,” March 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>
59. VA Memorandum “Proper Use of Email and Other Messaging Services,” January 2, 2018, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
60. “Product Line Management Transformation Playbook” version 3.1, August 2023, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>
61. NIST SP 500-267B Revision 1, “USGv6 Profile,” November 2020
62. OMB Memorandum M-21-07, “Completing the Transition to Internet Protocol Version 6 (IPv6),” November 19, 2020
63. Social Security Number (SSN) Fraud Prevention Act of 2017
64. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018
65. C.F.R Title 15 Part 7, “Securing the Information and Communications Technology and Services (ICTS) Supply Chain”, as amended
66. Executive Order 14028, “Executive Order on Improving the Nation's Cybersecurity,” May 12, 2021, <https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-on-strengthening-and-promoting-innovation-in-the-nations-cybersecurity/>

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

67. OMB Memorandum M-22-09, "Moving the U.S. Government Toward Zero Trust Cybersecurity Principles", January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.
68. NIST SP 800-52 Revision 2, "Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations"
69. OMB M-22-18, "Enhancing the Security of the Software Supply Chain through Secure Software Development Practices," September 14, 2022
70. OMB M-23-16, "Update to Memorandum M-22-18," June 9, 2023
71. OMB M-21-31, "Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents," August 27, 2021
72. NIST SP 800-88 Revision 1 "Guidelines for Media Sanitization," December 2014
73. CISA Binding Operational Directive (BOD) 19-02: "Vulnerability Remediation Requirements of Internet-Accessible Systems," April 29, 2019, [BOD 19-02: Vulnerability Remediation Requirements for Internet-Accessible Systems | CISA](#)
74. CISA BOD 22-01: "Reducing the Significant Risk of Known Exploited Vulnerabilities," November 3, 2021, [BOD 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities | CISA](#)
75. CISA BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks." Cybersecurity & Infrastructure Security Agency (CISA), [BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks | CISA](#)
76. VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, June 03, 2019
77. VA Memorandum, "VA Security Controls," January 17, 2025, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>

3.0 SOLUTION SALIENT CHARACTERISTICS

The proposed solution shall meet the following salient characteristics:

3.1 PLATFORM AND ARCHITECTURE

- a. Is a COTS, Software-as-a-Service (SaaS) offering aligned with VA's Zero Trust Data Monitoring and Sensing - Structured Data Protection initiative.
- b. Provides Cloud-Native Application Protection Platform capabilities.
- c. Implements Policy-as-Code for data categorization, discovery, and labeling of structured data and supports enforcement through Continuous Integration and Continuous Delivery pipelines across development, test, and production environments, as well as integration with data inventories, Security Information and Event Management (SIEM), and User and Entity Behavior Analytics (UEBA) platforms.
- d. Supports hybrid deployment across VA on-premises data centers and VA Enterprise Cloud (AWS GovCloud (US), Azure Government) under a unified SaaS control plane.

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

- e. Includes a SaaS control plane that holds a current Federal Risk and Authorization Management Program (FedRAMP) High authorization (Agency Authority to Operate (ATO) or Joint Authorization Board Provisional Authority to Operate ATO) prior to production use and maintains continuous monitoring.
- f. Does not require database connectivity.
- g. At the Government's option, integrates with VA Cybersecurity Operations Center (CSOC) automation and Extended Detection and Response platforms.

3.2 CONTINUOUS MAINTENANCE AND NON-DISRUPTION REQUIREMENT

- a. Operational Continuity. Contains sufficient people, processes, and technology, to remain fully functional and maintained in accordance with stated performance requirements for the entire period of performance. All operational, maintenance, and update activities—whether technical, procedural, or personnel-related—shall be performed entirely by the Contractor, without reliance on the Government for execution. The Government's role shall be limited to oversight, status review, and approvals where explicitly required VA policy and the contract terms.
- b. Non-Disruption and Risk Prevention. Ensures that operation, maintenance, updates, and related activities do not disrupt, interfere with, or degrade VA workloads, systems, or networks. All activities are performed in a manner that does not introduce new security vulnerabilities or increase risk to VA assets, operations or partners.
- c. Change-Safe Deployment Controls. Implements administrative controls to stage, validate, and deploy all changes—including scope, prerequisites, test/validation steps, risk assessment, and rollback procedures—within Government-approved change-control windows. It proactively coordinates change activities to maintain uninterrupted service and ensures compliance with applicable VA and Federal security requirements.
- d. Support, Escalation, and Third-Party Coordination (No additional cost to Government). Maintains established relationships, agreements, and entitlements with any third-party vendors necessary to support, troubleshoot, or enhance the solution. All coordination with such third parties is handled exclusively by the solution at no additional cost to the Government. All operations, maintenance actions, escalations, and third-party involvement are fully documented, transparent to the Government, and available for review upon request. Third party vendor involvement does not alter the stated performance requirements obligations or accountability to the Government; service levels for vendor escalation align with Key Performance Indicators.

3.3 SECURITY AND COMPLIANCE

- a. Cryptography. Uses cryptographic modules validated by NIST's Cryptographic Module Validation Program under FIPS 140-3 (or FIPS 140-2 modules on NIST's historical list only where permitted by VA policy) and allows disabling non-validated ciphers/protocols.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- b. Identity & Audit. Supports role-based access control that maps to VA Identity, Credential, and Access Management groups (e.g., Single Sign-On via Security Assertion Markup Language (SAML) 2.0/OpenID Connect) and captures all privileged administrative actions in append-only, tamper-evident audit logs with time synchronization and integrity verification.
- c. Accessibility. Administrative and user-facing interfaces conform to Section 508 and demonstrate Web Content Accessibility Guidelines (WCAG) 2.1 Level AA conformance; and makes available a current Voluntary Product Accessibility Template (latest Information Technology Industry Council template/edition) covering applicable criteria.
- d. Sustainable Acquisition (if hardware is furnished). Physical appliances meet applicable sustainable acquisition for ENERGY STAR® or Federal Energy Management Program-designated efficiency and Electronic Product Environmental Assessment Tool® registration—consistent with Federal Acquisition Regulation (FAR) 52.223-23 (Sustainable Products and Services) and U.S. Environmental Protection Agency's Recommendations of Specifications, Standards, and Ecolabels. (If no hardware is proposed, mark "Not Applicable.")

3.4 DISCOVER, CLASSIFY, AND LABEL STRUCTURED DATA.

- a. Native support for industry standard structured data platforms, systems, and clouds.
- a. Organizes data into classifications to enhance both its usability and protection: Improves data usability and protection by systematically organizing data into appropriate classifications. This structured approach ensures that data is managed efficiently and securely.
- b. Tags and labels data sources by classification: Implements tagging and labeling mechanisms to categorize data sources according to their classifications. This process facilitates easy identification and management of data assets.
- c. Connects a data object with detailed metadata: Links each data object with comprehensive metadata to provide detailed information about the data. This connection enables better management, retrieval, and usage of the data.
- d. Allows VA to append essential information to data assets including sensitivity levels (e.g., secret, confidential), classification criteria (e.g., health, financial records), retention guidelines (e.g. how long the data should be kept), and access limitations (e.g., who can view or modify the data), and customizable labels. Equips the VA with the capability to append crucial information to data assets. Such information includes sensitivity levels, classification criteria, retention guidelines, access limitations, and customizable labels, ensuring data is appropriately managed and protected.
- e. Creates and deploys policies based on classifications/labels.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- f. Enables informed, dynamic access decisions based on the specific context of the access request. Fosters the creation and deployment of policies that are informed by data classifications and labels. These policies enable dynamic and context-specific access decisions, enhancing security and compliance.

3.5 AUTOMATION

- a. Exports data security event and audit log data to Government-designated consuming security tools with end-to-end delivery latency of no more than 60 seconds, measured from event generation to availability for query in the consuming tool.
- b. Provides built-in automation that executes at least the following workflows: alert triage deduplication; incident case creation with enrichment; response playbook execution; and compliance report generation.
- c. Scales telemetry ingestion (e.g., gigabytes of log, flow, and data event data daily).
- d. Provides a unified compliance dashboard that consolidates posture information across compute, asset, application, product, and system boundaries. The dashboard generates exportable compliance reports aligned with applicable federal cybersecurity frameworks, including at minimum NIST 800-53, FedRAMP, and the Center for Internet Security benchmarks.
- e. Alerts for detected data loss events, misconfigurations, and policy violations. Alerts include plain-language descriptions, relevant identifiers, and remediation guidance.
- f. Exports audit logs of administrative actions and security events to VA's centralized log management, IT Service Management (ITSM), and SIEM platforms.
- g. Schedules and On-Demand Report Generation Reports are configurable for daily, weekly, monthly intervals.

4.0 SPECIFIC TASKS AND DELIVERABLES

4.1 PROJECT MANAGEMENT

4.1.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor's approach, timeline, and tools to be used in execution of this task order. The purpose of this plan is to ensure that the Government and the Contractor understand and manage risk, communications, schedules, deliverables, quality, and human resources. The contractor shall ensure the CPMP takes the form of both a narrative and graphic format to illustrate schedules, milestones, risks, and resource support. The CPMP shall also include procedures that detail how the Contractor shall coordinate and execute plans, routines, and ad-hoc data collection and reporting requests as identified within the PD. The Contractor shall provide the Contracting Officer's Representative (COR) and VA Program Manager (PM) with the CPMP within

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

10 business days after task order award and the CPMP shall be updated/maintained monthly thereafter throughout the period of performance. The contractor shall enable the Government to access the CPMP and associated artifacts in the VA SharePoint site or any other platform of the Government's choosing.

The CPMP shall be treated as a dynamic document, regularly reviewed and updated to reflect changing conditions, new information, and the Government's emerging priorities. The Contractor shall adopt a proactive approach to planning that ensures the CPMP remains relevant and a useful tool for guiding decision-making.

The baseline CPMP for the base year of the contract shall include the following milestones: Pilot Readiness Review (PRR), Mid-Pilot Review (MPR), and Pilot Exit Review/Go-No-Go (PER). These activities, along with their planned dates and criteria, must occur only during the base year and are aligned with the Deployment Plan (DP) Pilot Annex. They shall not take place in any option years of the contract.

The CPMP shall be comprised of the following subsidiary plans: Schedule Management Plan; Scope & Acceptance Management Plan; Staffing Management Plan (SMP) (with Organization Chart annex); Quality Control Plan; Performance Management Plan; Communications Plan (CP); and Risk Management Plan. Where a standalone deliverable is referenced elsewhere in this PD, the CPMP shall reference that deliverable and need not duplicate its content.

1. Schedule Management Plan: Includes GANTT charts and schedules of all planned deliverables; and, for the Base Period only, the Pilot Milestones: (a) PRR; (b) MPR; and (c) PER with Go/No-Go decision. Pilot milestone dates, entry/exit criteria, change windows, and rollback validation shall align to the DP Pilot Annex.
2. Scope & Acceptance Management Plan: Describes how the Contractor controls scope and deliverables and defines roles and responsibilities.

The Scope and Acceptance Management Plan shall include:

- a) Who has authority and responsibility for scope management.
 - b) How scope is measured and verified (e.g., Quality Checklists, Scope Baseline, Work Performance Measurements).
 - c) Who is responsible for final acceptance of project scope and deliverables.
3. SMP: Illustrates and details the arrangement of Management, Key and Support personnel assigned to the order, as well as corporate reach-back for staff augmentation. The SMP includes an Organization Chart (annex) for positions vacant and filled showing names, locations, team assignment, role, tour of duty/shift (as applicable), associated subcontractors, and reporting structure. The contractor shall update the Organization Chart within 15 days of any change.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

4. Quality Control Plan: Describes all work products and deliverables to meet the needs of the Government, are accurate, and free of errors or unacceptable number of defects.
5. Performance Management Plan: Outlines how performance will be monitored and measured for acceptance by the Government, including schedule adherence, effectiveness, and stakeholder satisfaction. The plan shall include performance tracking for integration support and alert triage during the Base-Period pilot, as defined in the Pilot Annex.
6. CP: Describes methods, timelines, and responsibilities for communication between the Contractor and the Government throughout the period of performance. The CP shall include:
 - a) List the Responsible–Accountable–Consulted–Informed and contact information of all management and key personnel for both the Contractor and the Government, with associated tasks, functional assignments, and relationships.
 - b) Identify a single, authorized point of contact (POC) who will serve as the sole liaison for all technical, operational, and administrative matters.
 - c) A designated POC who is empowered to coordinate directly with any subcontractors or third-party vendors, at no additional cost to the Government, to resolve issues and maintain continuous system operation.
 - d) Shall illustrate how to communicate with the designated POC during Monday–Friday, 0800–1700 Eastern Standard Time.
 - e) No duplication: The Communications Plan shall reference the Staffing Plan (Roster) in PD 4.1.2 - Contractor Personnel Management as the authoritative source for Contractor personnel; it shall not duplicate roster fields.
7. Risk Management Plan. Details risks that may impact contract success, including a common name/title, probability, impact, risk score, origin, explanation, planned/recommended mitigation, and time to close; otherwise, complete a Plan of Action & Milestones (POAM) for identified risks. In the base period only, the plan includes pilot-specific technical/integration risks with mitigations, owners, and closure criteria mapped to Pilot milestones.

The Contractor shall propose plan formats or templates that meet the Government's requirements. VA may provide templates/shells for each plan and the VA PM will provide guidance to the Contractor on the necessary inputs/ information that are required to develop the outputs for each one of the subsidiary plans. The above list may be updated by VA to include additional subsidiary plans and/or greater details.

Deliverable:

- A. Contractor Project Management Plan

4.1.2 CONTRACTOR PERSONNEL MANAGEMENT

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

The Contractor shall provide a Staffing Plan, (Roster) within three business days after award, following the requirements provided for each Section in the table below. The Contractor shall develop and present the Government with a Staffing Plan that includes the Labor Category (LCAT), resource function/role, resource name, status of background investigations, PD Task Section affiliation, requirements (experience and/or certifications) met, physical location, and onboarding / offboarding status as well as any positions that have not been filled. The ability to sort and filter on all categories shall be reflected in the Staffing Plan. The staffing plan shall also include Key Personnel Positions (See PD Section 4.1.7 - Personnel).

This Staffing Plan (Roster) implements and is governed by the CPMP's Staffing Management Plan (PD section 4.1.1). It is an operational roster, not a separate management plan; the CPMP shall reference this roster and need not duplicate the roster fields.

The Contractor shall provide a Contractor Manpower Report to the COR. The report is due weekly during the Transition-In period (until staffing is complete), and monthly thereafter (Staffing is complete). The report shall contain the following information for each person supporting this PD:

1. Name
2. Team Assigned
3. Role
4. Site Location
5. Contact Information
6. Start date.
7. Separation date
8. In/ Out processing progress status details (to include all aspects)
9. Background investigation progress status and date released.
10. Mandatory VA training completion dates.

The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the Task Order.

Deliverables:

- A. Staffing Plan (Roster)
- B. Contractor Manpower Report

4.1.3 ONBOARDING / OFFBOARDING

The Contractor shall manage Onboarding/Offboarding and administration of Contractor personnel who work under this Task Order. Onboarding/Offboarding shall be conducted through the VA Account Provisioning/Deprovisioning.

The Contractor Onboarding SOP shall include:

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

1. Scheduling appointments to submit electronic fingerprints.
2. Submitting request for Talent Management System (TMS) accounts.
3. Completing VA mandatory training for contractors
4. Coordinating completion of background request application using the Federal Electronic Questionnaires for Investigations Processing (e-QIP).
5. Completing and submit background investigation information and documents.
6. Coordinating PIV card issuance activities.
7. Completing and submit system account request forms.
8. Ensuring computer issuance is properly coordinated with VA Asset Management Team with coordination through the COR/ VA PM.
9. Ensuring all efforts for in-processing are coordinated and communicated to the COR.
10. Retain a log of all onboarding activities for personnel assigned to this effort, which shall be made available to the COR upon written COR request within 1 business day.
11. Completing and submitting documented requests for specific individuals who require elevated privilege to successfully execute this PD

Onboarding/offboarding VA Identity Management Toolkit portal link below:

<https://mvtkssoi.iam.va.gov/imdquiWeb/provManagedUserAcctSelf.action?action=requestAccount>

The Contractor shall identify individuals who require elevated privileges to the necessary development and test environments for the product lines.

After review between the Contractor and VA COR(s), a decision will be made as to the necessity of obtaining GFE for the onboarding staff. If approved, Contractor shall follow the appropriate steps to obtain the equipment.

A Contract Lead (single Contractor Onboarding POC) shall be designated by the Contractor that performs onboarding/offboarding and tracks the onboarding status of all Contractor personnel. The Contractor Onboarding POC shall be responsible for accurate and timely submission of all required VA onboarding documents to the VA COR(s). All VA onboarding (non-Personally Identifiable Information (PII)) documents shall be stored in the deliverables folder in the COR designated VA SharePoint site or equivalent tool. The Contractor Onboarding POC shall be responsible for tracking the status of all their staff's onboarding activities to include the names of all personnel engaged on the task, their initial training date for VA Privacy and Information Security training, and their next required training date. The Contractor Onboarding POC shall also report the status of the staff level in the Biweekly Status Report.

The Contractor shall manage all the offboarding processes for access to VA individual system/environment access for all Contractor staff. The Contractor shall prepare all forms necessary for termination of access to VA information systems, in accordance with VA guidance and policies. The Contractor shall confirm via email to COR, VA Team

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

and Lead whether the GFE equipment, associated documentation, and PIV card has been returned to the proper receiving authorities in accordance with VA policy.

The Contractor shall provide a Monthly On/Off-Boarding Status Report. The On/Off-boarding report shall be delivered in a Microsoft Office format, as determined by the government. The report is due no later than 15th of each month and shall be in accordance with the OIT/OIS writing style guide. The report shall include, at a minimum, the following items:

- a. Name of contractor employee
- b. Team
- c. Title
- d. Role (scope of work and responsibilities)
- e. Start Date
- f. Departure date
- g. List of assigned VA assets including PIV & attestation that all were returned.
- h. Attestation that all accesses (physical and logical) were revoked.
- i. Confirmation that relevant knowledge was transferred, and status of pending tasks/deliverables were appropriately reassigned.

The Contractor shall perform the efforts required for offboarding Contractor personnel assigned to this effort as defined in the OIS Contractor Offboarding SOP, to include:

1. Sending out notifications of termination.
2. Removal access.
3. Withdrawing of physical access.
4. Collecting issued property (computer, two factor authentication tokens).
5. Returning PIV Card to PIV Sponsor.
6. Circulating checklist.

Deliverable:

- A. On/Off-boarding Monthly Status Report

4.1.4 REPORTING REQUIREMENTS

The Contractor shall ensure that all reports, work products and deliverables submitted to the VA shall be in accordance with the OIT Brand System, and suitable for submitting to a non-technical senior management audience, and/or a technical audience.

The Contractor shall facilitate a weekly teleconference status meeting with the OIT staff to discuss progress against milestones, document issues, pending deliverables, and other pertinent topics concerning the task areas. During the weekly status meetings, the Contractor shall record the call and create meeting minutes utilizing Microsoft Word and include them in the Weekly Progress Reports. The Contractor shall provide Weekly Progress Reports which address issues, risks, risk mitigation strategies, progress

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

against milestones, and progress against schedules. Current risks shall be highlighted during weekly meetings. Past or mitigated risks shall be archived and available for later reference or review.

The Contractor shall ensure the minutes contain notes on all discussions, by topics and with details. The Contractor shall ensure that OIT Management, VA PM and applicable parties are informed of issues to prevent escalation.

The Contractor shall provide a weekly update of the Risk Management Plan in the CPMP to the COR. The risk management plan shall include a Risk Log, with an acceptable template to be provided by the COR. The Contractor shall detail all risks that impact successful execution of the PD with acceptable template to be provided by the COR. This includes a common name or title of the status, issue category, issue number, issue description, area affected, date open, date closed, risk identified, recommended mitigation, notes/next actions.

The Contractor shall submit a consolidated monthly deliverable acceptance report to the COR no later than two days prior to submitting the monthly invoice. This report must be delivered after obtaining the necessary signatures from the PM or task leads, confirming the completion and acceptance of deliverables. The COR will provide a template or guidelines for the minimal content required in the deliverable acceptance report. The Contractor is responsible for routing the deliverable acceptance report to the PM and task leads to obtain their acceptance signatures before submitting it to the COR.

Deliverables:

- A. Weekly Progress Reports
- B. Consolidated Deliverable Acceptance Report

4.1.5 TECHNICAL KICKOFF MEETING

The Contractor shall facilitate a technical kickoff meeting 10 days after task order award. The technical kickoff meeting shall be virtual. The Contractor shall coordinate the date, time, and location with the Contracting Officer (CO), as the Post-Award Conference Chairperson, the VA PM (Co-Chairperson), the Contract Specialist (CS), the COR, and OIT Leadership. The Contractor shall provide a draft agenda to the CO, the COR and the VA PM at least five calendar days prior to the meeting. Upon Government approval of a final agenda, the Contractor shall distribute the final version to all meeting attendees. During the kickoff meeting, the Contractor shall present, for review and approval by the Government, the details of the intended approach, work plan, and project schedule for each effort via a Microsoft Office PowerPoint presentation. At the conclusion of the meeting, the Contractor shall update the presentation with a final slide entitled "Summary Report" which shall include notes on any major issues, agreements, or disagreements discussed during the kickoff meeting and the following statement "As the Post-Award Conference Chairperson, I have reviewed the entirety of this presentation and assert that it is an accurate representation and summary of the discussions held during the Technical Kickoff Meeting for the Zero

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

Trust Data Monitoring and Sensing - Structured Data Protection contract.” The Contractor shall coordinate with the CS, prepare and distribute the Technical Kickoff Meeting minutes to the CO, COR, and all attendees within three calendar days after the meeting. The Contractor shall obtain concurrence from the CS on the content of the Meeting Minutes prior to distribution of the document.

Deliverables:

- A. Technical Kick-off
- B. Presentation Slides and Summary Report
- C. Approved Meeting Minutes

4.1.6 VA COMPLIANCE TRAINING

The Contractor shall ensure all Contractor personnel engaged on the Zero Trust Data Monitoring and Sensing - Structured Data Protection contract complete mandatory VA training before their due dates. The current mandatory requirements include VA Privacy and Information Security Awareness Training and Rules of Behavior Status. Role-based specific training of equivalent complexity may also be required. VA has the right to modify the training requirements. Completion of these training requirements are required during the onboarding of personnel and required before individuals start working under this task order.

The Contractor shall submit VA Privacy and Information Security Training Certificates for each Contractor employee in accordance with Section 9, Training, from Appendix C of the VA Handbook 6500.6, “Contract Security”. The contractor shall ensure that training referenced above is renewed annually by each contractor staff member.

The Contractor shall provide VA COR with progress and completion status of VA Privacy and Information Security Awareness Training and Rules of Behavior in the form of a Training Status Report on a monthly basis. The Training Status Report shall convey the following: first and last name of all Contractor personnel engaged on the effort, their initial training completion date(s), next required training date. The training status report and completion certificates shall be maintained by the Contractor in a VA provided central location.

Deliverable:

- A. Training Status Report

4.1.7 PERSONNEL

All personnel performing work on this task order shall possess experience, and competency in the disciplines and functional areas for the task to which they have been assigned. All personnel shall have knowledge of NIST security controls and possess sufficient understanding of industry standards to successfully execute the requirements in the Zero Trust Data Monitoring and Sensing - Structured Data Protection contract.

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

The Contractor shall provide Contractor support personnel and subcontractors who have the required skills, VA security clearance (when authorized), and access authorization or combination thereof to meet the requirements in the PD.

If there are any changes to personnel, the Contractor shall immediately notify the COR/VA PM in writing. The Contractor must replace any vacating personnel with individuals who have at least equal ability and qualifications as those currently performing in that role. This replacement must be completed within 30 calendar days, and the transition in or out must not affect the performance of the Zero Trust Data Monitoring and Sensing - Structured Data Protection solution.

All positions shall be filled within 30 calendar days after award.

4.1.8 AUTHORITY TO OPERATE (ATO)

The Contractor shall deliver a COTS SaaS solution in accordance with applicable Federal and Agency security policies. Where a proposed SaaS solution maintains a FedRAMP authorization but does not currently hold a VA ATO, the Contractor shall ensure that all required documentation, testing, and coordination activities are completed in order to obtain VA authorization and achieve full operational readiness for this SaaS capability within the VA environment.

The Contractor shall complete and provide all deliverables identified in this section in accordance with the timelines and requirements specified. The Contractor shall coordinate with VA Digital Transformation Center (DTC), COR, and Subject Matter Experts to ensure that all deliverables are accurate, complete, and sufficient to support VA's security authorization process. The contractor shall at minimum complete the following to obtain an ATO if the solution is FedRAMP Authorized and VA Authorized:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA) and have a current VA authorization.
2. The Contractor shall comply with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The FedRAMP Authorization level and existing VA ATO should be no less than the level required for this use case which has been defined as a 100% high system (per NIST 800-60 Vol 2).
4. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency authorization of the cloud service or migrated application.
5. The Contractor shall exclusively provide licenses and/or accounts to FedRAMP authorized and VA authorized environments.
6. The Contractor shall afford VA access to the Contractor's and Cloud Service Provider's (CSP) facilities, installations, technical capabilities, operations, documentation, records, and databases.

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

7. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall immediately bring the situation to the attention of the other party in accordance with Addendum B, VA Information and Information System Security/Privacy Language
8. The Contractor shall comply with data management requirements.
9. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
10. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
11. The Contractor shall provide continuous monitoring activities including scans, security artifacts, and monthly Plan of Action and Milestones (POAM) reports as outlined by FedRAMP requirements.

Deliverables:

- A. Continuous monitoring security artifacts
- B. Continuous monitoring scans
- C. Plan of Action and Milestones reports.

4.1.9 DEPLOYMENT AND IMPLEMENTATION SERVICES

The Contractor shall provide a turnkey delivery model following a phased implementation approach focused on structured data discovery, classification, labeling, and DLP enforcement across VA on-premises and VAEC (AWS GovCloud (US), Azure Government) environments. The Contractor shall develop a Deployment Plan (DP) that covers scope, schedule, prerequisites, dependencies/compatibility (including data repositories, Extract, Transform, Load (ETL) tools, and data services), and risk management strategies. Upon Government approval of the DP, the Contractor shall coordinate with Government technical teams to ensure seamless integration and shall provide regular progress updates to the VA Project Management Team, addressing issues, risks, and mitigations during implementation.

During the Base Period, the Contractor shall conduct a time-boxed pilot with 1 – 3 VA Systems, to validate deployment and integration, policy efficacy, and structured data protection on a representative subset of VA systems prior to enterprise rollout. The pilot shall include each of the following system types: relational databases, data warehouses, and cloud-native data services. The pilot shall also validate connectors, classification and labeling accuracy, DLP policy efficacy, and non-disruptive enforcement prior to enterprise rollout. The pilot shall begin in monitor/alert mode and progress to prevention/enforcement only after tuning and Government approval. The Contractor shall implement required integrations with VA-designated tools necessary for pilot operations and shall lead policy and alert tuning (rule hygiene, routing, baselining) against representative VA workloads. All changes shall occur within approved change windows with tested rollback paths. The pilot duration, scope, success criteria, and rollback procedures shall be defined in the DP's Pilot Annex. Oversight & Stage Gates. Government oversight will include stage-gated reviews (PRR, MPR, PER). These are

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

governance events with notes and minutes retained as artifacts; they are not separate deliverables.

For the Base Period only, pilot outcomes shall be included in the monthly Integration Status Report (ISR) under “Pilot Progress”. Weekly status shall include a Pilot Progress line item (scope coverage, summary of tuning changes, performance for integration support and alert triage, risks/issues/mitigations, upcoming change windows, and rollback tests executed).

The Contractor shall maintain pilot artifacts (DP/Pilot Annex, tuning and change logs, integration health checks, rollback evidence) and provide them upon request and at stage-gated reviews. Pilot exit criteria (acceptable detection efficacy, acceptable false-positive rates, acceptable performance overhead in monitor and prevention modes, and stable integration health) shall be proposed by the Contractor and approved by the Government. If exit criteria are unmet, the Government may direct additional pilot cycles or scope adjustments.

The DP Pilot Annex shall specify:

1. Representative systems (databases/data warehouses/data services),
2. Timelines, resource assignments, prerequisites, and dependency and compatibility assessments,
3. Integration endpoints/data flows,
4. Classification & labeling approach (test datasets, ground truth sampling, Quality Assurance criteria),
5. Policy tuning approach (rule hygiene, routing, baselining),
6. Approved change control windows and tested rollback plan,
7. Evidence to be produced (dashboards, event samples, label propagation traces, policy diffs, integration health checks),
8. Stage-gate plan (Readiness, Mid-Pilot, Exit) with entry and exit criteria, and
9. Scale-out plan requiring VA PM approval

The Contractor shall set up and configure the solution to full operational status and shall ensure integration with the Department’s network and security infrastructure, contingent upon Pilot Exit approval and a Government “Go” decision for scale-out.

The Contractor shall provide the monthly ISR for the duration of the contract documenting traceability of implementation and sustainment activities and the continued alignment of the Zero Trust Data Monitoring and Sensing - Structured Data Protection solution with VA systems and environments. The report shall summarize integration progress with key enterprise platforms, including but not limited to DevSecOps pipelines, configuration management platforms, incident response systems, UEBA, and SIEM and Security Orchestration, Automation, and Response (SOAR) technologies; identify completed integrations, active development items, decommissioned systems or tools, newly onboarded protected workloads, technical dependencies, and any gaps or issues requiring Government attention or mitigation; and note planned change windows and associated risk and impact. Base Period only: the report shall include a Pilot Progress subsection covering scope coverage, summary of tuning changes,

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

performance for integration support and alert triage, risks, issues, and mitigations, upcoming change windows, and rollback tests executed. The Pilot Progress subsection shall be removed from subsequent reports at Government direction upon completion of the Pilot Exit Review.

During each Option Year, the Contractor shall perform deployment and configuration activities necessary to:

1. Onboard new or changed VA systems and workloads
2. Implement major version upgrades to agents/connectors or the control plane that affect deployment posture
3. Add or modify integrations and data flows (e.g., SIEM and SOAR, UEBA, ticketing/orchestration, telemetry pipelines)
4. Address approved architecture changes (e.g., cloud migrations, segmentation, new environments)
5. Re-baseline configurations and policies required by emerging threats or VA policy. Work shall be executed only via Government-approved change requests and within approved change windows with tested rollback paths.

No pilot is required in the Option Years. The Contractor shall keep the DP current; material changes to deployment scope, integration endpoints, or rollback procedures shall be reflected in an updated DP within five business days of Government approval. Activities and outcomes shall be reported in the monthly ISR under "Deployment & Configuration Activities."

Deliverables:

- A. Deployment Plan
- B. Integration Status Report

4.1.10 OPERATIONS AND MAINTENANCE

The Contractor shall operate the structured data protection solution in a fully functional, secure, and compliant state throughout its lifecycle, covering discovery, classification, labeling, policy enforcement, monitoring, reporting, and evidence production.

The Contractor shall submit a Structured Data Protection Coverage Report on a monthly basis. In this Structured Data Protection Coverage report the contractor shall include a reconciliation of assets protected by the Zero Trust Data Monitoring and Sensing - Structured Data Protection solution against VA's authoritative asset inventory, including identification of any gaps in protection coverage.

The Structured Data Protection Coverage Report shall provide an accounting of the VA structured data assets actively protected by the Zero Trust Data Monitoring and Sensing - Structured Data Protection solution, compared to the total in-scope workload population. The report shall identify newly onboarded assets and gaps in coverage, along with planned remediation actions where applicable. This deliverable ensures VA

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

maintains an accurate understanding of the Zero Trust Data Monitoring and Sensing - Structured Data Protection solution's protection footprint and can validate that coverage aligns with current operational and security objectives.

The Contractor shall:

- a. Submit a monthly Data Protection Update Summary each month. The report shall include details of systems and data sets/elements covered, data events monitored/blocked, and number of ITSM tickets by status during the reporting period. The Summary will include metrics for sensitive data (Protected Health Information (PHI)/PII/Payment Card Industry – Data Security Standard (PCI-DSS)/custom VA labels), schema drift handling such as new tables, schema and lineage monitoring (maintaining lineage maps across ETL/ELT, replication, and analytics flows, and detect and report label drop or mislabel propagation), and tracking of false positives/negatives (policy efficiency: track and remediate policy false positives/negatives).
- b. Ensure that any unresolved support issues impacting integration with VA-owned systems—such as SIEM platforms, configuration management tools, or DevSecOps pipelines—are elevated to the VA Enterprise Service Desk for the submission of a ServiceNow ticket. This includes, but is not limited to, cases where the issue cannot be resolved through configuration of the solution alone and requires intervention by the government.
- c. Submit a Ticket Metrics Summary Report on a monthly basis. The report shall include the number of support tickets that were opened, closed, first-response and resolution times, severity distribution, and issue classification.
- d. Apply all operational, monitoring, reporting, and maintenance responsibilities to any new or existing protected workload added during the period of performance.
- e. Ensure that new or modified workloads introduced into the protected environment are properly onboarded, integrated, and configured in accordance with VA security and telemetry requirements.
- f. Schedule and facilitate a weekly coordination meeting with the designated VA Team Lead. These meetings shall cover topics such as protected host or application onboardings, telemetry performance, incident response, unresolved integration issues, upcoming releases, deliverable status, and any escalations. Minutes summarizing action items, decisions, and follow-up tasks shall be captured and distributed to attendees within one business day.
- g. Support contact and response times (business hours only). The Contractor shall provide a single support contact (email and phone) during VA business hours (Mon–Fri, 0800–1700, Eastern Standard Time) staffed by personnel qualified to triage solution issues and coordinate resolution with the SaaS provider as needed. Response-time expectations (business hours). After-hours: No after-hours support is required under this task order. Issues reported after hours will be acknowledged and handled beginning 0800 next business day.

Deliverables:

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- A. Structured Data Protection Coverage Report
- B. Data Protection Update Summary
- C. Ticket Metrics Summary

4.1.11 KEY PERFORMANCE INDICATORS REPORTING

The Contractor shall provide reports that demonstrate how Key Performance Indicators (KPI) metrics are being met throughout the performance of the requirements. The Contractor shall provide a Zero Trust Data Monitoring and Sensing – Structured Data Protection Efficacy & Operations Report that reflects the following KPIs, supported by evidence:

- a. Count of Data Elements Identified and Categorized (KPI 1). This metric represents the total number of data elements that have been discovered and properly categorized based on their content and sensitivity. Accurate identification and categorization are crucial for effective data management and protection. (Efficacy & Operations Report: Section 1)
- b. Count of Data Elements Labeled (KPI 2). This KPI tracks the number of data elements that have been tagged with labels such as PHI, PCI, PII, and any custom labels specific to the VA. Labeling data elements helps in implementing tailored policies and access controls. (Efficacy & Operations Report: Section 2)
- c. Count of Data Elements with Open Access – Remediated (KPI 3). This measures the number of data elements that initially had open access permissions but have since been secured and remediated. Reducing the count of open access data elements limits exposure and enhances data security. (Efficacy & Operations Report: Section 3)
- d. Count of products/systems with structured data on-boarded and covered with solution (KPI 4). This KPI indicates the number of products and systems containing structured data that have been integrated into the data security solution. Ensuring all relevant systems are covered is essential for comprehensive data protection. (Efficacy & Operations Report: Section 4)
- e. Number of DLP policies implemented and enforced (KPI 5). This metric shows the number of DLP policies that have been put into place and are actively enforced. Effective DLP policies help prevent unauthorized access and data breaches. (Efficacy & Operations Report: Section 5)
- f. Reduction in unauthorized data transfer incidents (target: % decrease within 12 months) (KPI 6). This KPI tracks the decrease in incidents of unauthorized data transfers over a specified period, typically aiming for a percentage reduction within 12 months. Achieving this target indicates improved data security measures. (Efficacy & Operations Report: Section 6)
- g. Percentage of sensitive structured data covered by active DLP rules (target: %) (KPI 7). This metric measures the proportion of sensitive structured data that is protected by active DLP rules. Meeting or exceeding the target percentage ensures sensitive data is adequately safeguarded. (Efficacy & Operations Report: Section 7)

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

- h. **System Uptime:** The percentage of time the solution is operational and available (KPI 8). This KPI measures the availability and reliability of the data security solution, represented as a percentage of time the system is operational. High uptime is critical for continuous protection and user trust. (Efficacy & Operations Report: Section 8)
- i. **Scalability Metrics (KPI 9).** The ability of the solution to handle increased loads, such as the number of applications or transactions it can protect without performance degradation: This metric assesses the solution's capacity to scale and manage increased demands without compromising performance. It is essential for ensuring the solution can grow with the organization's needs. (Efficacy & Operations Report: Section 9)
- j. **Integration Time (KPI 10).** The average time required to integrate the solution with existing systems and tools: This KPI measures the average duration required to successfully integrate the data security solution with existing systems and tools. Shorter integration times are preferable as they minimize disruption and expedite deployment. (Efficacy & Operations Report: Section 10)
- k. **User Training Completion Rate (KPI 11).** The percentage of users who successfully complete the training provided by the vendor: This metric tracks the proportion of users who have completed the training program provided by the vendor. High training completion rates ensure that users are knowledgeable about how to use the solution effectively and securely. (Efficacy & Operations Report: Section 11)
- l. **Support Response Time (KPI 12).** The average time taken by the vendor's support team to respond to and resolve support tickets: This KPI measures the efficiency of the vendor's support team in responding to and resolving issues, represented as an average response time. Prompt support is crucial for maintaining system reliability and user satisfaction. (Efficacy & Operations Report: Section 12)
- m. **Resource Utilization:** The amount of system resources (Central Processing Unit (CPU), memory, etc.) used by the solution during peak operation (KPI 13). This metric tracks the system resources consumed by the solution during peak operation times. Efficient resource utilization ensures optimal performance without overloading the system. (Efficacy & Operations Report: Section 13)

Deliverables:

- A. Zero Trust Data Monitoring and Sensing – Structured Data Protection Efficacy & Operations Report
- B. Evidence Package

4.1.12 KEY PERFORMANCE INDICATORS (KPI)

The Contractor shall ensure that the Data Monitoring and Sensing – Structured Data Protection solution consistently achieves and maintains, at a minimum, the following KPIs Applicability and Contractor Obligation. The Contractor shall meet or exceed all

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

KPI thresholds defined in this Section during pilot and production operations. KPI performance shall be measured and reported as specified in this Section. Failure to meet any KPI constitutes nonconforming services and requires corrective action to restore compliance. Use of third-party or subcontractor products or services does not relieve the Contractor of any obligation.

KPI	Metric	Target	Cadence	Evidence
KPI 1	Count of Data Elements Identified and Categorized	Baseline	Monthly	Performance documentation
KPI 2	Count of Data Elements Labeled	Baseline	Monthly	Performance documentation
KPI 3	Count of Data Elements with Open Access - Remediated	Baseline	Monthly	Performance documentation
KPI 4	Count of Products/systems with structured data on-boarded and covered with solution.	Baseline	Monthly	Performance documentation
KPI 5	Number of DLP policies implemented and enforced.	Baseline	Monthly	Performance documentation
KPI 6	Reduction in unauthorized data transfer incidents (target: % decrease within 12 months).	Baseline	Monthly	Performance documentation
KPI 7	Percentage of sensitive structured data covered by active	Baseline	Monthly	Performance documentation

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

	DLP rules (target: %).			
KPI 8	System Uptime: The percentage of time the solution is operational and available.	≥ 99.95% uptime	Monthly	Performance documentation confirming service availability during each billing cycle
KPI 9	Scalability Metrics: The ability of the solution to handle increased loads, such as the number of applications or transactions it can protect without performance degradation.	Baseline	Monthly	Performance documentation
KPI 10	Integration Time: The average time required to integrate the solution with existing systems and tools.	Baseline	Monthly	Performance documentation
KPI 11	User Training Completion Rate: The percentage of users who successfully complete the training provided by the vendor.	Baseline	Monthly	Performance documentation
KPI 12	Support Response Time: The average time taken by the	Baseline	Monthly	Performance documentation

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

	vendor's support team to respond to and resolve support tickets.			
KPI 13	Resource Utilization: The amount of system resources (CPU, memory, etc.) used by the solution during peak operation.	Baseline	Monthly	Performance documentation

4.1.13 PERFORMANCE INDICATOR NARRATIVES

KPI 1 - Count of Data Elements Identified and Categorized

By tracking the count of data elements identified and categorized, the Solution is thoroughly scanning and understanding the data landscape. This comprehensive identification and categorization process is fundamental to applying the appropriate data protection measures.

KPI 2 - Count of Data Elements Labeled

Monitoring the count of data elements labeled ensures that the Solution is effectively tagging and labeling sensitive information according to predefined standards and requirements. Proper labeling facilitates the implementation of targeted security policies, reducing the risk of data breaches.

KPI 3 - Count of Data Elements with Open Access – Remediated

Measuring the remediation of data elements with open access indicates that the Solution is actively identifying and securing vulnerable data. This proactive approach shows that the Solution is reducing exposure to potential security threats and protecting sensitive information.

KPI 4 - Count of Products/systems with structured data on-boarded and covered with solution

This metric demonstrates the Solution's diligence in ensuring that all relevant products and systems containing structured data are integrated into the security solution. Comprehensive onboarding and coverage are essential to provide blanket protection across the organization's data ecosystem.

KPI 5 - Number of DLP policies implemented and enforced

Tracking the number of implemented and enforced DLP policies reflects the Solution's commitment to preventing unauthorized data access and transmission. An effective set

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

of DLP policies is a key indicator that the Solution is prioritizing data security through proactive measures.

KPI 6 - Reduction in unauthorized data transfer incidents (target: % decrease within 12 months)

Monitoring the reduction in unauthorized data transfer incidents supports assessments of the Solution's effectiveness in preventing data leaks and breaches over time. Achieving targeted decreases highlights the Solution's success in enhancing security protocols and reducing vulnerabilities.

KPI 7 - Percentage of sensitive structured data covered by active DLP rules (target: %)

This metric ensures that a significant portion of sensitive structured data is protected by active DLP rules, reflecting the Solution's thoroughness in securing critical information. Meeting or exceeding the target percentage demonstrates the Solution's effectiveness in applying data loss prevention strategies.

KPI 8 - System Uptime

The percentage of time the solution is operational and available: Ensuring high system uptime indicates that the Solution is maintaining a reliable and consistent security solution. Continuous availability is vital for safeguarding data without interruptions, thus reflecting the Solution's commitment to performance and reliability.

KPI 9 - Scalability Metrics

The ability of the solution to handle increased loads, such as the number of applications or transactions it can protect without performance degradation: Evaluating scalability metrics shows that the Solution's solution can handle growing demands without compromising performance. This capability ensures that data protection measures remain effective even as the organization's needs expand.

KPI 10 - Integration Time

The average time required to integrate the solution with existing systems and tools: Measuring integration time enables assessments of the Solution's efficiency in deploying the security solution within the existing infrastructure. Faster integration times minimize disruption and enable quicker protection of data assets, indicating the Solution's proficiency.

KPI 11 - User Training Completion Rate

The percentage of users who successfully complete the training provided by the vendor: A high user training completion rate ensures that users are well-versed in utilizing the security solution effectively, enhancing overall data protection. It reflects the Solution's commitment to comprehensive user education and support.

KPI 12 - Support Response Time

The average time taken by the vendor's support team to respond to and resolve support tickets: Monitoring support response time ensures that the Solution provides prompt and

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

effective assistance when issues arise. Quick resolution of support tickets is crucial for maintaining system stability and user confidence.

KPI 13 - Resource Utilization

The amount of system resources (CPU, memory, etc.) used by the solution during peak operation: Tracking resource utilization ensures that the Solution's solution is efficient and does not overburden system resources during peak operation. Efficient resource management is key for sustaining optimal performance and reliability.

4.1.14 TECHNICAL TRAINING

The Contractor shall provide virtual training once per quarter at the Government's request, for knowledge transfer to VA staff and others, for incident response, oversight and validation, access control and delegation awareness and audit & compliance.

- The Contractor shall provide Training material that includes user and administration guides, along with tutorials in the form of step-by-step walkthroughs that include text, images and videos.
- On the first Monday of each month, the Contractor shall ensure that training materials are updated to reflect new and updated software modules. A report including date, update, new features and description shall be included in training material.

Deliverables:

- A. Virtual Training
- B. Training Material (including training report)

5.0 NOTICE OF THE FEDERAL ACCESSIBILITY LAW AFFECTING ALL INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) PROCUREMENTS (SECTION 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

5.1 SECTION 508 – INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) STANDARDS

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255](#)

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

[Guidelines \(access-board.gov\)](https://www.access-board.gov). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with “508 Chapter 2: Scoping Requirements” for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

5.2 COMPATABILITY WITH ASSISTIVE TECHNOLOGY

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

5.3 ACCEPTANCE AND ACCEPTANCE TESTING

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above. The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

6.0 GENERAL REQUIREMENTS

6.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.3 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the Integrated Control Number (ICN) in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA Master Person Index (MPI) for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 "USGv6 Profile" (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 "Guidelines for

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

the Secure Deployment of IPv6” (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.5 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor’s proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.6 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative” (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 “Secure External Connections”, and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>.)

6.7 GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS

If Artificial Intelligence (AI) is part of the Contractor system/solution, the Contractor shall be in compliance with E.O. 13960 and 14319, OMB Memorandums M-25-21, M-25-22, and M-26-04, and VA Directive and Handbook 6500 to support VA in trustworthy, secure, responsible, accountable, Truth Seeking, and Ideologically Neutral AI innovation.

No web-based, publicly available generative AI service has been approved for use with VA-sensitive data including, but not limited to OpenAI’s ChatGPT, Microsoft’s Copilot, Google’s Gemini, and Anthropic’s Claude. No PII, protected health information (PHI), or VA-sensitive data should be entered into these unapproved services. The entire definition of VA Sensitive Data can be found at 38 U.S.C. § 5727 (23). The Contractor shall protect VA Sensitive data from unauthorized disclosure or use, and from being

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

used to train or improve the functionality of the vendor's commercial offerings without express permission from VA.

The Contractor shall deliver the services, technical data, configurations, models, weights, documentation or other information, including source code, developed during contract performance. The Contractor, in collaboration with VA, must evaluate the output of any AI tool for accuracy prior to using the output in VA efforts. All data, including models, weights, algorithms, and outputs generated using either Government-furnished data or data first developed under this contract shall be the property of the Government with unlimited rights as defined by FAR 52.227-14. The Contractor shall also deliver any custom-developed code developed with AI methodologies in accordance with the SHARE IT Act, if applicable. VA shall also retain unlimited rights to any improvements to that data, including the continued design, development, testing, and operation of AI systems and/or systems utilizing AI.

The Contractor shall ensure that all AI Systems, including Large Language Models (LLM), whether standalone LLMs or integrated into broader software platforms, procured under this effort and/or used in performance of this contract complies with the Unbiased AI Principles as defined in Executive Order 14319 and OMB Memorandum M-26-04, e.g. Truth Seeking and Ideologically Neutral, as applicable to the intended use of the system.

The Contractor shall ensure that AI System/LLM generated outputs are truthful in responding to user prompts seeking factual information or analysis, prioritize historical accuracy, scientific inquiry, and objectivity, as well as acknowledge uncertainty where reliable information is incomplete or contradictory and do not fabricate, hallucinate, or present unverifiable information as fact.

The Contractor shall ensure that LLMs and AI outputs are neutral, nonpartisan tools that do not manipulate responses in favor of ideological dogmas such as Diversity, Equity, and Inclusion (DEI). The Contractor shall ensure that the LLMs, including the AI System, are not intentionally encoded with partisan or ideological judgments within an AI System's/LLM's outputs unless those judgments are prompted by or otherwise readily accessible to the end user.

Compliance with the AI requirements of this contract, including adherence to the Unbiased AI Principles, Truth-Seeking and Ideological Neutrality requirements, disclosure obligations, monitoring and reporting requirements, and corrective action responsibilities, is a material condition of eligibility for payment and continued performance. In accordance with OMB Memorandum M-26-04, failure to comply with these requirements, or refusal to take timely and appropriate corrective action to remedy identified noncompliance, may constitute a material breach of contract and may result in remedies consistent with the terms of the contract and applicable law including but not limited to withholding of payment, termination for cause/default, or other appropriate contractual remedies, as determined by the Contracting Officer.

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

All AI for delivery and/or use in performance of the contract shall adhere to the VA *Trustworthy AI Framework*, available at <https://department.va.gov/ai/trustworthy/>. Once the Contractor has obtained CO authorization to use specific AI in contract performance, the Contractor shall provide the COR a signed Statement of Attestation prior to AI implementation as identified in the Artificial Intelligence in VA Contracts clause, to include its associated list of AI being used in contract performance.

Deliverable:

- A. Statement of Attestation

6.7.1 AI SYSTEM/LLM DEVELOPMENT AND OPERATION DOCUMENTATION REQUIREMENTS

To enable Government continued assessment of compliance with Trustworthy AI requirements and both Unbiased AI Principles, Truth-seeking and Ideological Neutrality, in accordance with OMB M-26-04, the Contractor shall provide AI System/LLM Development and Operation Documentation Package to include, at a minimum:

1. Acceptable Use Policy

The Contractor shall provide an Acceptable Use Policy document governing its AI operation that characterizes and differentiates appropriate and inappropriate use of their product offering

2. Model Cards, System Cards and/or Data Cards

The Contractor shall provide documentation describing essential information about the model, system, and or data as it relates to the AI/LLM product offering. The documentation shall address summaries of training process, identified risks and mitigations, and model evaluation scores on LLM benchmarks at a minimum, where appropriate

3. End User Resources

The Contractor shall provide documentation to include product tutorials, developer guides, and/or other tools to assist VA in ensuring proper use of the AI/LLM to maximize utility

4. Mechanism for End User Feedback

The Contractor shall provide documentation describing the mechanism employed to provide feedback to the Offeror on outputs identified that violate the Unbiased AI Principles. This may be satisfied by a general inbox, specific Point of Contact, or similar feedback mechanism.

5. Pre-Training and Post-Training Activities of the AI System/LLM

The Contractor shall provide documentation of Pre-Training and Post Training Activity that provides details on:

- a. Actions taken that impact the factuality and grounding of AI System/LLM outputs
- b. System-level prompts that provide natural language instructions to the model specifying guidelines on responding to user-generated queries, to include how a model responds when reliable information is incomplete, contradictory, or subject to individual interpretation
- c. The type of outputs restricted via content moderation and safety filters
- d. The use of red teaming as a means of continuously assessing the model to protect against incidents of bias in generated output.
- e. Training or development, if any, that occurred outside the United States, to include the type of activity and the country in which it occurred.
- f. Any modifications or configurations undertaken to comply with any regulation from a government other than the U.S. Federal Government.

6. Model Evaluation Results and Methodologies

The Contractor shall provide documentation describing the Evaluation Results of bias evaluations conducted by the Vendor to include the methodology for performing such tests (e.g., testing prompt pairs for politically oriented topics).

The documentation shall also include Benchmark scoring results measuring the model's bias, helpfulness, honesty, or accuracy when provided with ambiguous versus straightforward questions. (Including any benchmarks comparing performance across multiple languages, where applicable).

7. Description of Enterprise-Level Controls

The Contractor shall provide documentation describing the Enterprise Governance tools and controls, such as:

- a. Customizable system instructions that are additive to a base model's system prompts or content generation filters.
- b. Product features that require a model to cite sources of its outputs or otherwise provide visibility into the provenance of the model's outputs.
- c. AI System/LLM model evaluation tools that enable comparisons either between a model's outputs, or across various models.

8. Third Party Modification Disclosure

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

The Contractor shall disclose of any additional controls to modify an AI Model's/LLM's output applied by the Contractor if the Contractor is not a direct developer of the LLM (e.g., classifiers, system prompts, fine-tuning, content moderation and filters, etc.)

Deliverable:

- A. AI System/LLM Development and Operation Documentation Package

6.7.2 MONITORING, REPORTING, AND CORRECTIVE ACTION

The Contractor shall develop and implement a Compliance Monitoring and Reporting Plan supporting ongoing monitoring processes to evaluate AI outputs for compliance with Trustworthy AI and Unbiased AI principles. This plan shall include the mechanism for authorized users to provide end user feedback to report suspected violations of Truth-Seeking or Ideological Neutrality requirements.

The Contractor shall notify the COR within 10 business days of identifying any material deviation from these principles and shall submit a written Corrective Action Plan describing mitigation steps, responsible parties, and timelines. Any material deviation, corrective action taken, and results shall be detailed in the *<Weekly or Monthly>* Progress Reports.

Deliverable:

- A. Compliance Monitoring and Reporting Plan
- B. Corrective Action Plan

6.7.3 AI MODEL UPDATES AND CHANGE DISCLOSURES

The Contractor, in an AI Model/LLM Change Disclosure, shall notify the Government throughout the PoP in advance of any material changes to AI models, including new AI enhancements, features and/or components, controls, retraining, classifiers, system prompts, fine-tuning, content moderation, filters, version replacement, or architectural changes, that could reasonably affect compliance with Trustworthy AI or Unbiased AI principles. Updated documentation shall be provided to VA for VA approval prior to implementation of such changes.

Deliverable:

- A. AI Model/LLM Change Disclosure

6.8 SOURCE CODE HARMONIZATION AND REUSE IN INFORMATION TECHNOLOGY (SHARE IT ACT)

(If it is determined that the SHARE IT Act applies, please include this entire section to the PD as a new Section 5.8, entitled "Source Code Harmonization and Reuse in Information Technology (SHARE IT) Act", change the text to black and convert to "No Spacing" style font. Otherwise remove this Section)

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

The Contractor shall comply with the Source Code Harmonization and Reuse in Information Technology (SHARE IT) Act when developing custom software source code first produced for the VA in the performance of this Contract/Order. The Contractor shall deliver to the Government all data first produced under this Contract/Order with unlimited rights as defined by FAR 52.227-14, to include without limitation, all custom developed software source code and other key technical components of the code (including documentation, data models, schemas, metadata, architecture designs, configuration scripts, and artifacts required to develop, build, test, and deploy the code). Custom-developed software source code includes source code, or segregable portions of source code and all documentation created in support thereof to include source code written for a software project, product, module, plugin, script, middleware, or application programming interface.

SECURITY AND PRIVACY REQUIREMENTS

6.9 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Vetting Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PD are:

**Position Sensitivity and Background Investigation Requirements
by Service Task/Item Number**

Service Task / Item Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
4.1.8	☐	☐	☒
4.1.9	☐	☐	☒
4.1.10	☐	☐	☒
4.1.11	☐	☐	☒
4.1.14	☐	☐	☒

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.10 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- a. The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- b. Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2.1 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations will be placed on the Historical List. See FIPS Transition Effort Timeline for more details: <https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)
- c. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Personnel Security Adjudication Center (PSAC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- d. The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed PSAC Fingerprint Request Form
- e. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Defense Counterintelligence and Security Agency (DCSA) National Background Investigation Services (NBIS) Electronic Application (eAPP) (formerly e-QIP) after receiving an email notification from the PSAC.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- f. The Contractor employee shall certify and release the eAPP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the PSAC. These documents shall be submitted to the COR within 3 business days of receipt of the eAPP) notification email. (Note: DCSA is moving towards a “click to sign” process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via eAPP).
- g. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- h. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 4), signed “Contractor Rules of Behavior”, and with a valid, operational Personal Identity Verification (PIV) credential for PIV-only logical access to VA’s network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by DCSA. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of DCSA.
- i. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
- j. Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.
- k. PIV Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

- A. Contractor Staff Roster

ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B.2 VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General. The primary clause used to define computer software license (not data/intellectual property first produced under this Contractor or order) is FAR 52.227-19, Commercial Computer Software License.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor's information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.
- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.

- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.
- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.

- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.
- b. Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.
- c. All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Suitability and Security Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- d. All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.
- e. The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:
 - (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
 - (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.
 - (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
 - (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- f. In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.

- g. Contractors/Subcontractors who no longer require VA accesses will return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

- a. All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:
 - (1) VA Privacy and Information Security Awareness and Rules of Behavior course TMS #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].
- b. The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five days of the initiation of the contract and annually thereafter, as required.
- c. Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5.SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.

- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
- e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
- f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.

- g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- a. Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).
- b. Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.
- c. VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- d. The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-22-18 and M-23-16 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change after the issuance date of M-22-18 (September 14, 2022). The term "software" includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO)14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one approved by the agency will be acceptable in lieu of a software producer's self-attestation.
- e. The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- f. The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.
- g. The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- h. The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default “program files” directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- i. Applications designed for normal end users will run in the standard user context without elevated system administration privileges.
- j. The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this will only be granted with the written approval of the COR/CO.
- k. The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- l. The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- m. The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as “Information Systems”) throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations, workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems (including systems, operating systems, products, hardware, software, applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.
- n. When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.
- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.

- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.
- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.

- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.
- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.
- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.
- c. The Contractor shall provide or arrange for the provision of technical justification as to why any "false positive" hit has taken place to ensure their code's supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.
- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter "virus or other malware") onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA's information networks, computer systems and information systems; and
- (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor's products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:
 - (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.

Zero Trust Data Monitoring and Sensing - Structured Data Protection Draft Product Description

If updates cannot be deployed within the specified timeframes, the Contractor shall deploy compensating controls or mitigations using configuration changes, access control rules, runtime policy adjustments, or other technical safeguards within the solution's existing security architecture.

The Contractor shall document the mitigation approach in a written report that includes the following at a minimum:

- Description of the vulnerability and why the patch could not be deployed on time;
- Details of the mitigation or workaround implemented, including specific configuration or policy actions taken;
- Assessment of effectiveness, including expected residual risk and detection capabilities;
- Timeline for full remediation if applicable (e.g., when the patch will be available);
- Impact on system performance or functionality, if any.

This documentation shall be submitted to the Government COR and CO no later than the original remediation deadline (30 or 7 business days, depending on severity).

- c. The solution shall ensure timely remediation of vulnerabilities in all components used within the contractor-managed environment, including commercial, proprietary, and open-source products.

The solution shall deploy new security updates within 30 calendar days of availability from the supplier.

The solution Remediations for critical vulnerabilities, including those identified as high risk, actively exploited, or listed in authoritative threat bulletins (e.g., CISA KEV)—shall be applied within seven business days of release.

I All data, metadata, logs, reports, security events, analytics, threat intelligence, telemetry, and derivative information generated, processed, collected, stored, or transmitted by the solution on behalf of the Government shall remain the sole property of the Department of Veterans Affairs (VA), regardless of whether such data resides on contractor-provisioned infrastructure, cloud services, or third-party platforms.

The Contractor shall have no ownership interest in VA data or any derivative artifacts. The Contractor shall ensure that VA has continuous, on-demand access to its data throughout the period of performance.

Upon expiration or termination of the contract, the Contractor shall return all VA data to the Government in a mutually agreed upon format and shall certify the secure deletion of all VA data from contractor-controlled systems, backups, and

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

cloud storage environments, in accordance with VA and NIST data sanitization standards.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

- a. Contractor supplies/delivered Medical Devices, Special Purpose Systems-Operational Technology (SPS-OT) and Research Scientific Computing Devices shall comply with all applicable Federal law, regulations, and VA policies. New developments require creation, testing, evaluation, and authorization in compliance with processes specified on the Specialized Device Cybersecurity Department Enterprise Risk Management (SDCD-ERM) Portal, VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, VA Handbook 6500, and the VA Information Security Knowledge Service. Deviations from Federal law, regulations, and VA Policy are identified and documented as part of VA Directive 6550 and/or the VA Enterprise Risk Analysis (ERA) processes for Specialized Devices/Systems processes.
- b. All Contractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500 and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO for governance or resolution.
- c. The Contractor shall certify to the COR/CO that devices/systems that have completed the VA Enterprise Risk Analysis (ERA) process for Specialized Devices/Systems are fully functional and operate correctly as intended. Devices/systems must follow the VA ERA authorized configuration prior to acquisition and connection to the VA computing environment. If VA determines a new VA ERA needs to be created, the Contractor shall provide required technical support to develop the configuration settings. Major changes to a previously approved device/system will require a new ERA.
- d. The Contractor shall comply with all practices documented by the Food Drug and Administration (FDA) Premarket Submission for Management of Cybersecurity in Medical Devices and Post market Management of Cybersecurity in Medical Devices.
- e. The Contractor shall design devices capable of accepting all applicable security patches with or without the support of the Contractor personnel. If patching can only be completed by the Contractor, the Contractor shall commit the resources needed to patch all applicable devices at all VA locations. If unique patching instructions or packaging is needed, the Contractor shall provide the necessary information in conjunction with the validation/testing of the patch. The Contractor shall apply security patches within 30 business days of the patch release and

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

have a formal tracking process for any security patches not implemented to include explanation when a device cannot be patched.

- f. The Contractor shall provide devices able to install and maintain VA-approved antivirus capabilities with the capability to quarantine files and be updated as needed in response to incidents. Alternatively, a VA-approved whitelisting application may be used when the Contractor cannot install an anti-virus / anti-malware application.
- g. The Contractor shall verify and document all software embedded within the device does not contain any known viruses or malware before delivery to or installation at a VA location.
- h. Devices and other equipment or systems containing media (hard drives, optical disks, solid state, and storage via chips/firmware) with VA sensitive information will be returned to the Contractor with media removed. When the contract requires return of equipment, the options available to the Contractor are the following:
 - (1) The Contractor shall accept the system without the drive, firmware and solid state.
 - (2) VA's initial device purchase includes a spare drive or other replacement media which must be installed in place of the original drive at time of turn-in; or
 - (3) Due to the highly specialized and sometimes proprietary hardware and software associated with the device, if it is not possible for VA to retain the hard drive, firmware, and solid state, then:
 - (a) The equipment Contractor shall have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact.
 - (b) Any fixed hard drive, Complementary Metal-Oxide-Semiconductor (CMOS), Programmable Read-Only Memory (PROM), solid state and firmware on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the solicitation, contract, or order.

B.14 DATA CENTER PROVISIONS

Zero Trust Data Monitoring and Sensing - Structured Data Protection
Draft Product Description

- a. The Contractor shall ensure the VA network is accessed by in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- b. The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.
- c. The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- d. The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.
- e. The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- f. The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.